

DECISION REQUESTED

We can't prove what's in our software

Customers ask. Regulators are starting to. So does our own incident response. Today we answer by hand, slowly, and never quite the same way twice.

What I'm asking you to approve

Make a bill of materials a standard output of every release, starting with one product team.

What it needs

One engineer, part time, for two weeks. No purchase, no new vendor, no headcount.

What it costs

Roughly [\$___] of engineering time to prove it. The software itself is free and already written.

What you get back

Evidence from our own code by [date], and a recommendation either way.

Three things that are true today



A customer asks what's inside the product. We assemble the answer by hand, and the deal waits while we do.



A serious vulnerability hits the news. We can't say that morning whether it's in anything we ship.



US federal purchasing already requires this list. The EU Cyber Resilience Act phases in through 2027.

What that costs us now

[]

engineer-days a quarter spent
answering security
questionnaires

[]

deals last year where a
compliance review pushed the
close date

[]

hours to answer "are we
exposed?" the last time
it mattered

All three recur, and all three are paid for by pulling senior engineers off product work.

Why we can't simply buy this

The tools on the market were built for the ecosystems most companies use. We build on conda packages and Python wheels together, and that combination is the part they handle badly.

A bought tool reports

A clean inventory, missing a large share of what we actually install — with no error to tell us.

Which is the dangerous case

An incomplete list we trust is worse than no list. We'd answer the customer, and be wrong.

The tool we'd use instead is already built, already runs against our lockfiles, and costs nothing.

What changes

The question	Today	After
What's in release 4.2?	Days of archaeology	A file, written at build time
Are we exposed to this vulnerability?	Ask every team, wait	Search one document
Can we pass this customer's review?	Rebuilt by hand each time	Attach the standard file
Did a restricted license get in?	Nobody is checking	The build stops before it ships

Same engineers, same release process. The answers stop being projects.

What I'm not claiming

This is not a security product

It tells us what we ship. The tools that hunt for vulnerabilities still do that job, and now they get a complete list to work from.

It won't find what upstreams never published

Where a license or an advisory doesn't exist, the document records the gap rather than guessing. We'd rather show a known blank than a wrong answer.

It isn't a compliance program

It produces the evidence. Someone still has to own the process, and that ownership question is worth settling separately.

What if this turns out to be wrong?

- ✔ No contract, no subscription, no vendor who can raise the price or be acquired
- </> Open source under Apache-2.0, so the code stays available to us whatever happens to it
- 📖 Output is CycloneDX and SPDX, the two industry standards — no lock-in to switch away from
- 🏗 Released, versioned and tested on every platform we build on
- 👤 Maintained by [name] here; small enough that someone else could take it over
- ⚠ Worst case: we stop running it and delete one step from one pipeline

WHAT I NEED FROM YOU

Say yes to two weeks on one product.

I'll come back with the bill of materials from a real release, what it found that we didn't know, and a plan to make it standard — or a recommendation to drop it.

[Presenter] · decision requested by [date]